



METODOLOGÍA PARA LA GESTIÓN DE RIESGOS OPERACIONALES

Código Interno	M.RI.001.014	Administración de Riesgos – Riesgos Operacionales	Fecha de Publicación
Elaboró / Actualizó	Ana Chávez / Luis Camilo Mejía		28-08-2024
Revisó	Gloria Piernagorda	INFORMACIÓN CONFIDENCIAL	Versión
Aprobó	Luis Camilo Mejía		14

TABLA DE CONTENIDO

1. INTRODUCCIÓN	4
2. OBJETIVO	5
3. ALCANCE	5
4. DEFINICIONES	5
5. POLITICAS O NORMAS DE OPERACIÓN	5
6. PRINCIPIOS PARA LA GESTIÓN DE RIESGOS	6
7. GESTIÓN DE RIESGOS	7
8. CONTROLES OPERATIVOS	29
9. RESPONSABILIDAD	30
10. DOCUMENTOS DE REFERENCIA	30

1. INTRODUCCIÓN

Gestionar riesgos es el deber ser de organizaciones que se mueven en entornos de alta competitividad y vulnerabilidad, no hacerlo, causa problemas que pueden ser graves y que incluso ponen en peligro su supervivencia; pero gestionarlos no necesariamente es garantía de éxito. Es importante reconocer la relación existente entre la gestión de riesgos y la toma de decisiones.

La necesidad de plantearse la adopción de una metodología para la Gestión de Riesgos Operacionales en Compunet tiene su origen en el cumplimiento de los requisitos de la nueva versión ISO 9001:2015, la contribución en la toma de decisiones y en la mejora, y estandarización de los procesos.

Esta metodología pretende de una manera sistemática, hacer que la gestión del riesgo operacional dentro de Compunet se convierta en parte integral de los procesos del negocio y que todos y cada uno de los Colaboradores incorporen dentro de su día a día la importancia de la detección y el control de los riesgos que más impacto pueden tener sobre los resultados finales de la empresa.

En el documento se toman algunos preceptos teóricos de la Norma ISO 31000 Gestión del Riesgo; en ellas se plantean metodologías que fundamentalmente constan de una serie secuencial y lógica de pasos, que inician con el establecimiento del contexto y la identificación, seguido del análisis, evaluación, tratamiento, comunicación y monitoreo de los riesgos de la empresa.

Al introducir este tipo de metodologías se inicia la transformación de la cultura organizacional, convirtiendo la gestión del riesgo en una herramienta de mejoramiento continuo, que conduce necesariamente a una cultura de la calidad y a un mejor servicio al cliente que en últimas es el fundamento de la existencia de las empresas.

2. OBJETIVO

Establecer un marco conceptual y metodológico mediante el cual Compunet gestione sus riesgos operacionales identificados que puedan afectar el cumplimiento de la misión y de los objetivos estratégicos corporativos.

3. ALCANCE

Aplica para la identificación, medición, control y monitoreo de los riesgos potenciales u ocurridos dentro de los procesos que hacen parte del alcance de la certificación ISO 9001:2015 en el Sistema de Gestión de la Calidad de Compunet.

4. DEFINICIONES

Las definiciones deben ser consultadas en el siguiente enlace:

https://wiki.grupocnet.com/index.php/BANCO_DE_DEFINICIONES

5. POLITICAS O NORMAS DE OPERACIÓN

- a) La Identificación, análisis, evaluación y tratamiento de los riesgos operacionales es responsabilidad del Dueño del Proceso y Dueños de los Riesgos.
- b) Cuando el nivel de un riesgo residual sea “Alto” o “Extremo” es indispensable la formulación de un plan de mitigación que contribuya a la reducción de este nivel y evite la materialización del riesgo. En caso de que se trate de un riesgo residual “Moderado”, es potestad del Dueño del Proceso definir si es necesario o no dicho plan.
- c) Todos los controles asociados a los riesgos operacionales deben tener los respectivos soportes que evidencien su eficacia y ser verificados por el Área encargada del Sistema Integrado de Gestión y/o bajo la metodología ISAE 3402 de acuerdo con el seguimiento del numeral 7.4.6.
- d) Es responsabilidad de quién haya identificado un riesgo operacional materializado reportarlo al Dueño del Proceso con copia a sistemadeintegradodegestion@grupocnet.com

- e) Es responsabilidad del Dueño de Proceso analizar, reportar y/o generar un plan de mitigación a los riesgos operacionales materializados (documentados o no en la matriz) en cumplimiento al **“P.GI.004 Correcciones, Acciones Correctivas y Acciones de Mejora”**.

6. PRINCIPIOS PARA LA GESTIÓN DE RIESGOS

A continuación, se adoptan como principios de la metodología los establecidos por la Norma ISO 31000¹:

PRINCIPIO	DESCRIPCION
 Crear y proteger el valor	Contribuye a la consecución de objetivos, así como a la mejora de aspectos tales como la seguridad y salud laboral, cumplimiento legal y normativo, protección ambiental, etc.
 Estar incorporada en todos los procesos	No debe ser entendida como una actividad aislada sino como parte de las actividades y procesos principales de una organización.
 Ser parte del proceso para la toma de decisiones	La gestión del riesgo ayuda a la toma de decisiones evaluando la información sobre las distintas alternativas de acción.

¹ Definiciones tomadas de International Standard ISO 31000-2009

PRINCIPIO	DESCRIPCION
 Ser usada para tratar con la incertidumbre	La gestión de riesgo trata aquellos aspectos de la toma de decisiones que son inciertos, la naturaleza de esa incertidumbre y como puede tratarse.
 Ser estructurada, sistemática y oportuna	Contribuye a la eficiencia y consecuentemente, a la obtención de resultados fiables.
 Basada en la mejor información disponible	Las entradas del proceso de gestión de riesgos están basadas en fuentes de información como la experiencia, la observación, las previsiones y la opinión de expertos.
 Adaptarse a su entorno	Hecha a su medida, alineada con el contexto externo e interno de la organización y con su perfil de riesgo.
 CONSIDERAR FACTOR HUMANO Y CULTURAL	Reconoce la capacidad, percepción e intenciones de la gente, tanto externa como interna que pueda facilitar o dificultar la consecución de los objetivos de la organización.
 Ser transparente, inclusiva, y relevante	La apropiada y oportuna participación de los grupos de interés y, en particular, de los responsables a todos los niveles, deben asegurar que la gestión del riesgo permanece relevante y actualizada.

PRINCIPIO	DESCRIPCION
 Dinámica, sensible al cambio e iterativa	La organización debe velar para que la gestión de riesgos detecte y responda a los cambios de la empresa. Conocer como ocurren los acontecimientos externos e internos, cambio del contexto, nuevos riesgos que surgen y otros que desaparecen.
 Facilitar la mejora continua de la organización	Las organizaciones deberían desarrollar e implementar estrategias para mejorar continuamente, tanto en la gestión del riesgo como en cualquier otro aspecto de la organización.

Tabla No.001

7. GESTIÓN DE RIESGOS

7.1. ¿QUÉ ES RIESGO?

Riesgo:

Cualquier circunstancia, evento, amenaza, acto, decisión u omisión que pueda en un momento dado impedir el logro de los objetivos estratégicos formulados por la alta dirección o la exitosa implementación de las estrategias.

Para identificarlos es necesario



1. El objetivo y alcance del proceso, proyecto o contrato.
2. Los productos o salidas del proceso, proyecto o contrato.
3. Las características o requisitos de los productos o salidas identificados.
4. Con las características o requisitos identificados determina los riesgos asociados.

El riesgo no está expresamente limitado a acontecimientos negativos o eventos inesperados, también contempla la ausencia o subaprovechamiento de acontecimientos positivos u oportunidades.

7.2 TIPOS DE RIESGOS EN COMPUNET

El mapa de procesos de Compunet se compone de los siguientes Tipos de riesgos:

❖ **Riesgos Operacionales:**

Es el riesgo de incurrir en pérdidas directas o indirectas resultante de fallas o inadecuados procesos, personas y sistemas internos o por eventos externos.

❖ **Riesgos de Seguridad de la Información.**

Potencial de que una amenaza determinada explote las vulnerabilidades de los activos de información o grupos de activos causando así daño a la organización. (ISO/IEC 27005:2008). Esto riesgos se ven reflejados a través de la ***“M.RI.002 Metodología de Gestión de Riesgos de la Seguridad de la Información”*** y el ***“F.RI.052 Matriz y Mapa de Riesgos de la Seguridad de la Información”***.

❖ **Riesgos de Seguridad y Salud en el Trabajo:**

El riesgo laboral es la posibilidad de que un trabajador sufra una enfermedad o un accidente laboral. Estos riesgos están documentados a través del procedimiento ***“P.RI.013 Identificación de Peligros, Evaluación y Valoración de Riesgos”*** y la ***“F.RI.050 Matriz de Identificación de Peligro, Evaluación y Valoración de Riesgos”***.

Metodologías por Tipos de Riesgos



Imagen No. 001

7.3. ¿QUÉ ES GESTIÓN DE RIESGOS?

La Gestión de Riesgos se direcciona a través del Sistema Gestión de Calidad y el alcance de la certificación ISO 9001:2015, los cuales están fundamentados en la Norma Técnica Colombiana NTC 31000. Lo anterior con el propósito que todos los colaboradores de Compunet, identifiquen, valoren y mitiguen los eventos que pueden afectar negativamente impedir el logro de los objetivos y asegurar que el SIG pueda lograr sus resultados previstos.

7.4. PROCESO PARA LA GESTIÓN DEL RIESGO

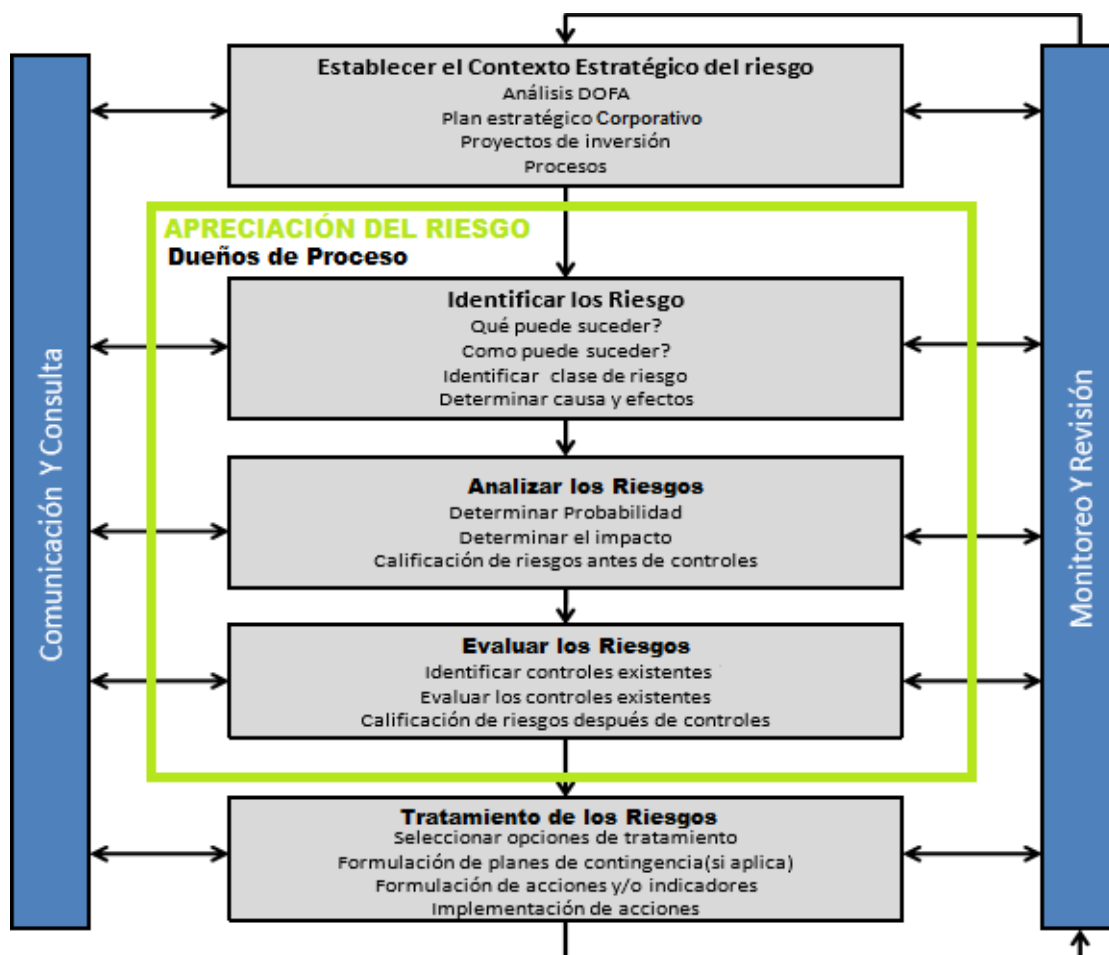


Imagen No. 002

Dentro de la gestión del riesgo operacional se tendrá el siguiente ciclo de gestión del riesgo:



Imagen No. 003

7.4.1 Contexto Estratégico del Riesgo

Establecer el contexto de toda la organización incluyendo el nivel estratégico, misional y de apoyo es importante, porque permite conocer las posibles situaciones generadoras de riesgos y facilitar su análisis y valoración, debido a que de este análisis se puede extraer información importante que puede orientar el manejo de los riesgos. Esta primera etapa permite identificar circunstancias que pueden afectar el cumplimiento de los objetivos corporativos:

- Definiendo la relación entre la organización y el ambiente en el que opera: Aspectos financieros, operacionales, competitivos, políticos, imagen, sociales, clientes, culturales y legales, Partes interesadas definidas en Planeación Estratégica.

- Validar la matriz DOFA generada en el proceso de Planeación Estratégica.

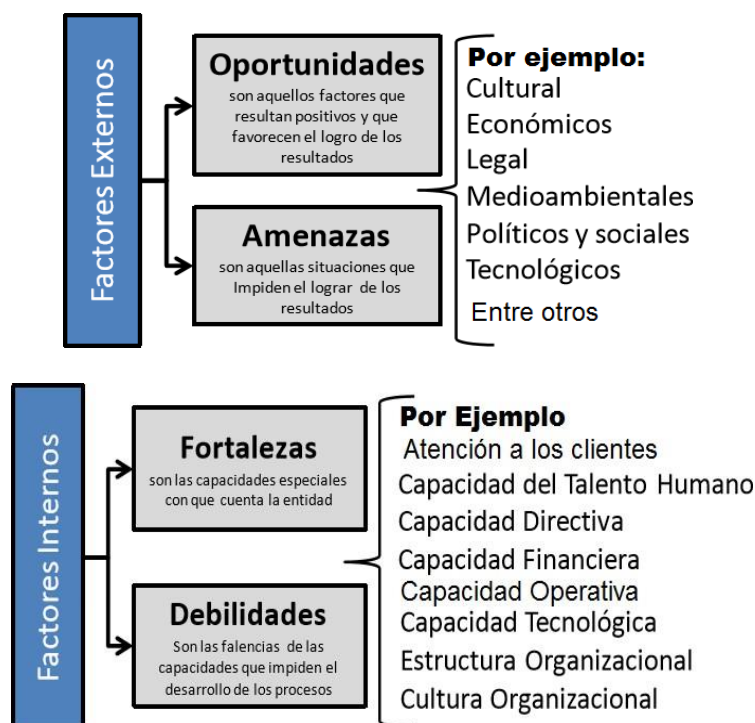


Imagen No. 004

- Identificar Objetos críticos: Entendiendo por objeto, la unidad funcional, el proceso, la actividad o cualquier otro elemento en que se pueda subdividir la organización y sobre el cual se pueda efectuar la gestión de riesgos.
- Identificando las partes interesadas de la organización y entendiendo sus necesidades y expectativas; Las partes interesadas que son pertinentes para el SIG son: Clientes, Gobierno y Organizaciones no Gubernamentales, Trabajadores, Prestadores de Servicios, Competidores, Proveedores externos, Partners-Aliados, Entidades Financieras y Accionistas.

El contexto estratégico es la base para la identificación del riesgo, dado que su análisis suministra la información sobre las causas del riesgo.

7.4.2 Identificación de los Riesgos

En esta etapa se realiza la identificación del qué, por qué y cómo pueden surgir elementos que puedan llegar a ser causales de generación de riesgos. Se identifican de forma sistemática las posibles causas concretas de los riesgos y los posibles efectos que se podrían llegar a presentar. Algunas preguntas que se puede realizar:



Imagen No. 005

Para que se pueda decir que existe un riesgo, deben estar presentes tres elementos: primero, la posibilidad de que algo suceda (un **evento**); segundo, que dicho evento sea generado por alguna condición (**causa**) y tercero que ese evento genere un efecto (**consecuencias**).

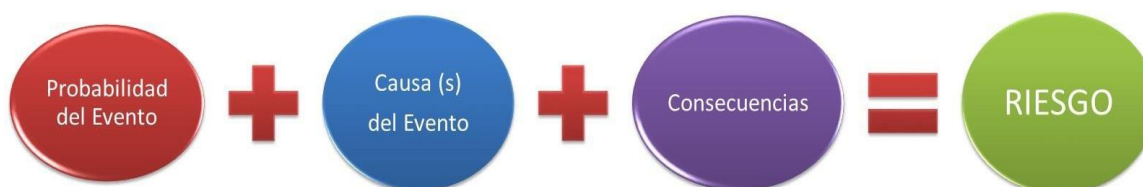


Imagen No. 006

Para identificar los riesgos se debe:

-
- Entender el proceso, el proyecto o el objeto del contrato (incluida revisión de los procedimientos y recolección de información).
 - Identificar los objetivos y actividades del proceso, las etapas del proyecto o las obligaciones del contrato.
 - Identificar las entradas, salidas, productos y/o resultados finales del proceso, o entregables del proyecto o contrato.
 - Entender la actividad o parte de la organización para la cual se aplicará la identificación.
 - Identificar “que puede fallar” ya sea en el proceso general o por actividad, o en el proyecto general o en sus etapas.
 - Otras preguntas que se pueden hacer al identificar los riesgos son:
 - ¿Qué puede suceder?
 - ¿Por qué sucede?
 - ¿Cómo sucede?
 - ¿Dónde puede suceder?
 - ¿Cuándo puede suceder?
 - Definir las causas (factores internos y externos): son los medios, las circunstancias y agentes generadores de riesgo.
 - a. Internas atribuidas a personas, métodos, equipos, materiales e instalaciones, directamente involucradas en el proceso o procedimiento. Por ejemplo:
 - Comportamientos humanos.
 - Actividades y controles gerenciales.
 - Aspectos tecnológicos o técnicos internos.
 - Actividades individuales.
 - Circunstancias económicas internas.
 - Relaciones comerciales o legales.

b. Externas cuando provienen del entorno en el que se desarrolla que tienen la capacidad de originar un riesgo. Por ejemplo:

- Eventos naturales.
 - Aspectos tecnológicos o técnicos externos.
 - Circunstancias políticas o legislativas.
 - Circunstancias económicas externas.
- Los efectos (consecuencias): Constituyen las consecuencias de la ocurrencia del riesgo sobre los objetivos de la entidad; generalmente se dan sobre las personas o los bienes materiales o inmateriales con incidencias importantes tales como daños físicos y fallecimiento, sanciones, pérdidas económicas, de información, de bienes, de imagen, de credibilidad y de confianza, interrupción del servicio y daño ambiental.

7.4.3 Análisis del Riesgo (Inherente)

El análisis del riesgo busca establecer la probabilidad de ocurrencia de este y sus consecuencias, este último aspecto puede orientar la clasificación del riesgo, con el fin de obtener información para establecer el nivel de riesgo inherente y las acciones que se van a implementar, sin considerar los controles existentes para evitar que este riesgo se materialice.

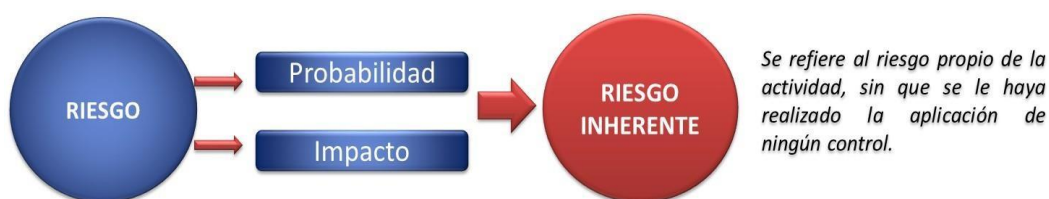


Imagen No. 007

Siempre que se realice una identificación de riesgos se debe realizar el análisis de estos, el cual debe ser direccionado por el Dueño del Proceso y/o Dueño del Riesgo con el acompañamiento del Jefe del Sistema Integrado de Gestión y/o el Especialista Seguridad de la Información.

Factores a tener en cuenta:



Imagen No. 008

Probabilidad

Se entiende como la posibilidad de ocurrencia del riesgo; esta puede ser medida con criterios de frecuencia, si se ha materializado (por ejemplo: número de veces en un tiempo determinado), o de factibilidad teniendo en cuenta la presencia de factores internos y externos que pueden propiciar el riesgo, aunque este no se haya materializado.

Para valorar la probabilidad de ocurrencia se utilizan los siguientes criterios:

Escala de Probabilidad

CALIFICACIÓN	CATEGORÍA	ESCALA CUALITATIVA	ESCALA CUANTITATIVA
5	Muy Probable	Se espera la ocurrencia del evento en la mayoría de las circunstancias.	Se espera una ocurrencia mayor al 30% del total de los casos o de las posibilidades.
4	Probable	El evento ocurrirá en casi cualquier circunstancia.	Se espera una ocurrencia entre el 21 y el 30% del total de los casos o de las posibilidades.

CALIFICACIÓN	CATEGORÍA	ESCALA CUALITATIVA	ESCALA CUANTITATIVA
3	Moderada	El evento ocurrirá en algún momento.	Se espera una ocurrencia entre el 11 y el 20% del total de los casos o de las posibilidades.
2	Baja	El evento puede materializarse esporádicamente.	Se espera una ocurrencia entre el 5% y el 10% del total de los casos o de las posibilidades.
1	Muy Baja	El evento puede materializarse fortuitamente	Se espera una ocurrencia menor al 5% del total de los casos o de las posibilidades.

Tabla No. 002

Para utilizar la escala cuantitativa, se deben contar con información de datos o registros de trazabilidad en los que se pueda evidenciar claramente la ocurrencia de los eventos de riesgo.

Impacto

Hace referencia a las consecuencias que se pueden generar en la organización con la materialización del riesgo.

Cada uno de los riesgos puede tener uno o más tipos de impactos, por lo que a continuación se incluye una para cada tipo de impacto.

Escala de Impacto

CALIFICACIÓN	CATEGORÍA	DESCRIPCIÓN	EJEMPLO
5	Catastrófico	Si el hecho llegara a presentarse, tendría desastrosas consecuencias o efectos sobre la entidad.	Legal: Los impactos generan sanciones legales, financieras, cierre de la Empresa.
			Reputacional: Los impactos generan oposición general de los medios de comunicación y pérdida definitiva de clientes.
			Operativo: Impacto de paro total del proceso.
			Económico: Se reduce el patrimonio efectivo mayor > 6%.
4		Si el hecho llegara a	Legal: Los impactos generan sanciones legales y financieras.

CALIFICACIÓN	CATEGORÍA	DESCRIPCIÓN	EJEMPLO
	Mayor	presentarse, tendría consecuencias o efectos sobre la Empresa	Reputacional: Los impactos generan oposición general de los medios de comunicación y pérdida considerable de clientes.
			Operativo: Impacto en intermitencia del servicio.
			Económico: Se reduce el patrimonio efectivo entre 3 - 6%
3	Moderado	Si el hecho llegara a presentarse, tendría medianas consecuencias o efectos sobre la entidad	Legal: Los impactos generan amonestaciones por entes de control.
			Reputacional: Los impactos generan relativa atención de los medios locales de comunicación y/o pérdida temporal de clientes.
			Operativo: Impacto en cambios en la interacción de los procesos.
			Económico: Se reduce el patrimonio efectivo entre 0.30 - 3%
2	Menor	Si el hecho llegara a presentarse, tendría bajo impacto o efecto sobre la entidad	Legal: Los impactos generan peticiones, quejas o reclamos.
			Reputacional: Los impactos generan circunstancias que afectan procesos o servicios alteran los compromisos establecidos con los clientes.
			Operativo: Impacto en cambios en procedimientos.
			Económico: Se reduce el patrimonio efectivo entre 0.12 – 0.30%
1	Insignificante	Si el hecho llegara a presentarse, tendría bajo impacto o efecto sobre la entidad	Legal: Los impactos no generan procesos legales.
			Reputacional: Los impactos son de conocimiento interno de la empresa, pero no de interés público.
			Operativo: Impacto en ajustes a una actividad concreta.
			Económico: Se reduce el patrimonio efectivo menos de 0.12%

Tabla No. 003

Nivel de riesgo

La combinación del impacto y probabilidad de ocurrencia del riesgo determinan su grado de severidad, el cual de acuerdo a lo establecido puede ser tipificado como Extremo, Alto, Moderada o Bajo.



Imagen No. 009

A partir de este nivel de riesgo se obtiene la Matriz de Riesgo **Inherente**, la cual constituye el primer estado de riesgo consolidado de la Organización.



Imagen No. 010

7.4.4 Evaluación del Riesgo

a. Definición de Controles para Tratar el Riesgo

Los controles son utilizados como primera instancia para tratar el Riesgo Inherente y evitar su materialización. Para identificar los controles se debe:

- Identificar las actividades y puntos de control existentes en el proceso que se está analizando.
- Revisar dentro de los procedimientos las actividades marcadas como de control (ítem controles operativos).

- Revisar políticas y normas existentes que incluyan puntos de control para el proceso.
- Recordar que los controles pueden ser de gestión, operativos o legales.

Los controles se implementan con el fin de:

- a) detectar un posible evento de riesgo.
- b) reducir la probabilidad del riesgo.
- c) reducir el impacto del riesgo.
- d) reducir tanto la probabilidad como el impacto.

Los controles que se asocien a los riesgos deben contar con las siguientes características y de acuerdo a cada una de ellas, cuenta con un % de efectividad asignado de la siguiente manera:

Característica	Clasificación	Significado	% Efectividad
Tipo de Control	Preventivo	Se utiliza como barrera de seguridad para que el riesgo no se presente y/o se materialice. Este control actúa directamente sobre las causas generadoras del riesgo disminuyendo la probabilidad de ocurrencia del mismo.	90%
	Detectivo	Es considerado como herramienta de alarma, que se activa cuándo identifica o detecta una situación poco común. En ocasiones estos controles pueden utilizarse para evaluar la eficacia de los controles preventivos.	60%
	Correctivo	Permite corregir las deficiencias que se pueden dar en un proceso y prevenir que estas se vuelvan a presentar. Este control se aplica posterior a la materialización del riesgo, y permite mejorar los demás controles implementados.	30%

Característica	Clasificación	Significado	% Efectividad
Ejecución del Control	Automática	Los controles automatizados son procedimientos programados que se encuentran diseñados para prevenir, detectar y corregir errores o irregularidades que pudieran tener un impacto. Los controles automáticos se enfocan desde los aspectos esenciales del procesamiento de los datos, desde la actividad de inicio hasta la actividad de generación de reportes o actividad final.	95%
	Semi Automática	Para la aplicación automática del control debe existir una configuración manual de manera previa.	60%
	Manual	Son las personas las directamente responsables de realizar o ejecutar la aplicación del control.	40%
Origen del Control	Obligatorio	Son aquellos que pueden estar representados por las leyes, normatividad y regulación, son impuestos a la empresa para que cumpla con sus actividades puntuales de negocio.	90%
	Mandatorio	Son aquellos que son directrices directas de la Alta Dirección o que se encuentran documentados en alguna política, manual o procedimiento de un proceso el cual el responsable del control no es Dueño	60%
	Voluntario	Son elegidos por el Dueño del Proceso o el Dueño del Riesgo para apoyar las actividades propias cada proceso.	40%
Documentación del Control	SI	El control se encuentra en algún documento del Sistema Integrado de Gestión. Se debe indicar el nombre y código del documento	80%
	NO	El control NO encuentra en algún documento del Sistema Integrado de Gestión.	40%
Frecuencia del Control	Por Evento o Diaria	El control se ejecuta cada vez que se presenta un evento asociado al riesgo o diariamente	95%
	Mensual	El control se ejecuta cada mes	80%
	Bimestral	El control se ejecuta cada 2 mes	70%
	Trimestral	El control se ejecuta cada 3 meses	60%
	Semestral	El control se ejecuta cada 6 meses	40%
	Anual o Bianual	El control se ejecuta 1 vez al año o cada 2 años	20%

Tabla No. 004

b. Efectividad del Control

Teniendo en cuenta el porcentaje otorgado a cada clasificación de las características del control descrito en la Tabla No. 003, se calcula el porcentaje final de efectividad por cada uno de los controles que debe ser verificado en la evaluación para garantizar su cumplimiento.

c. Evaluación de los Controles

Para comprobar que los controles son efectivos frente al riesgo identificado y contribuyen a que no se materialicen, de manera anual se debe llevar a cabo la evaluación de los controles para determinar lo siguiente:

- **Si el control reduce el impacto o la probabilidad:** se valida si con la ejecución del control se logra una disminución en el impacto y/o la probabilidad identificada en el análisis del riesgo inherente. Si el control no reduce ni impacto ni probabilidad se considera no eficaz.
- **Si el control es eficaz:** si las características definidas en el diseño del control se están cumpliendo de la manera en que se establecieron (tipo, ejecución, origen, documentación y frecuencia) se considera eficaz. Por cada criterio cumplido, se suma un porcentaje de eficacia hasta obtener un 100% de acuerdo a lo siguiente:

Cumple con	Porcentaje de eficacia
Tipo de Control	20%
Ejecución del Control	20%
Origen	20%
Documentación	20%
Frecuencia	20%

Tabla No. 005

De acuerdo a la validación que se realice en los anteriores puntos, se determina la pertinencia del control y si se debe ajustar alguna de sus características, de esta manera se comprueba el porcentaje de efectividad de cada uno de ellos y su eficacia frente al riesgo; este es el insumo principal para la evaluación del Riesgo Residual.

d. Evaluación del Riesgo (Residual)

En esta evaluación se verifica si el riesgo inherente tras la aplicación de los controles definidos anteriormente, su porcentaje de efectividad y la evaluación de la eficacia realizada logran disminuir la severidad del Riesgo para obtener el riesgo residual; para esta evaluación, se tiene como base el impacto del riesgo inherente definido en la identificación.

7.4.5 Tratamiento del Riesgo

Consiste en seleccionar y realizar la aplicación de las actividades más aptas y específicas, con el objetivo de poder disminuir el nivel del riesgo y evitar las posibles consecuencias derivadas de su materialización. Entre las opciones para tratar el riesgo se tienen:



Imagen No. 011

Al elegir algunas de estas opciones para tratar el riesgo, es necesario contar con la adecuada justificación del porqué se debe aplicar la opción elegida frente al análisis del riesgo realizado previamente.

En caso de que el nivel del Riesgo Residual sea “Alto” o “Extremo” es indispensable la formulación de un plan de mitigación que contribuya a la reducción de este nivel

y evite la materialización del riesgo de acuerdo con lo definido en el procedimiento **“P.GI.004 Correcciones, Acciones Correctivas y de Mejora”**. En caso de que se trate de un riesgo residual “Moderado”, es potestad del Dueño del Proceso O Dueño del Riesgo definir si es necesario o no dicho plan.

7.4.6 Monitoreo y Revisión de los Riesgos

El monitoreo y revisión de los riesgos, se realiza desde los siguientes frentes:

- **Dueños de Proceso:** El monitoreo individual de los riesgos lo realizan los Dueños de Proceso y se debe hacer dependiendo el nivel de riesgo, de la siguiente manera:

NIVEL DE RIESGO	COLOR	FRECUENCIA
EXTREMO	ROJO	Bimestral
ALTO	NARANJA	Trimestral
MODERADO	AMARILLO	Semestral
BAJO y MUY BAJO	VERDE	Anual

Tabla No. 006

A través de este monitoreo se revisa el estado de los riesgos y sus controles, y se puede tener como base los siguientes aspectos para lograr la mejora continua de los riesgos:

- Modificaciones al proceso en el periodo.
- Vigencia de las causas identificadas.
- Estado de los controles, aplicación y efectividad.
- Estado y cumplimiento de los proyectos, planes operativos o de acción asociados para la mitigación del riesgo.
- Reporte de eventos de riesgo.
- Informes de entes de control o de consultorías realizadas.

- **Responsables de Cada Control:** Los controles establecidos para mitigar los riesgos identificados deben ser ejecutados bajo las características definidas (tipo, ejecución, origen, documentación y frecuencia); así mismo custodiar la evidencia soporte por parte de cada responsable asignado y mantenerla disponible para consulta y/o verificación del Dueño de Proceso, del Sistema Integrado de Gestión y de las auditorías internas o externas asociadas al Sistema de Gestión de Calidad (NTC ISO 9001:2015).
- **Seguimiento Anual:** El seguimiento al “**Registro F.RI.001 Registro Matriz de Riesgos Operacionales**” debe ser realizado por el Dueño del Proceso al menos una vez por año, informando el estado general de los riesgos y los cambios que se han presentado al Sistema Integrado de Gestión (correo sistemaintegradodegestion@grupocnet.com).
- **Control y Seguimiento Planes de Tratamiento:** Es realizado por el Dueño del Proceso a los responsables de su ejecución de acuerdo con el plan definido y las fechas comprometidas.

Seguimiento Planes de Tratamiento y Administración de Riesgos Operacionales

- El seguimiento al “**Registro F.RI.001 Registro Matriz de Riesgos Operacionales**” es realizado por el Jefe del Sistema Integrado de Gestión y/o Especialista Seguridad de la Información al menos una vez por año, informando el estado general de los riesgos y solicitando a los Dueños de Proceso la identificación y/o actualización de los riesgos operacionales asociados a cada Proceso.
- Para los procesos (Gestión de Proyectos, Operación del Servicio, Gestión de Continuidad del Servicio, Gestión de la Configuración, Gestión del Cambio, Gestión de la Capacidad, Gestión de la Entrega, Gestión de Seguridad de la Información y Gestión de Seguridad informática) se debe realizar la revisión de controles bajo la metodología ISAE 3402.
- El Seguimiento a los planes de tratamiento, la verificación de su eficacia y cierre los realiza el Jefe del Sistema Integrado de Gestión y/o Especialista Seguridad de la Información de acuerdo con lo establecido en “**P.GI.004 Correcciones, Acciones Correctivas y Acciones de Mejora.**”

- La verificación y retroalimentación de la Administración del Riesgo Operacional la realizan los Auditores a través de los informes de auditoría internas y externas alcance certificación ISO 9001:2015.

7.4.7 Comunicación y Consulta de los Riesgos

Con el fin de socializar y formalizar una cultura de administración de riesgos, se ha tiene implementado los siguientes mecanismos:

- Metodologías, políticas operativas y demás información documentada son divulgadas a través del Sistema Integrado de Gestión y publicadas para consulta en: CnetWiki / Sistema Integrado de Gestión / Administración de Riesgos / Riesgos Operacionales.
- La matriz de Riesgos Operacionales por Proceso es divulgada por el Sistema Integrado de Gestión, sensibilizada por cada Dueño de Proceso y para consulta en: Cnetwiki / Sistema Integrado de Gestión / Administración de Riesgos / Riesgos Operacionales.
- Comunicaciones del Sistema Integrado de Gestión con recordatorios y campañas a personal del alcance de la certificación ISO 9001:2015 y a los Dueños de Proceso de acuerdo con el **“F.CO.002 Plan de Comunicaciones del SIG”**.

7.5. RESPONSABILIDADES EN LA GESTIÓN DE RIESGOS

Presidente

- Destinar y mantener los recursos necesarios para garantizar la adecuada implementación, mantenimiento y mejoramiento de la Gestión del Riesgo Operacional.

Vicepresidente Servicios de Tecnología(Representante de la Alta Dirección SIG)

- Evaluar periódicamente la efectividad y cumplimiento de todas y cada una de las etapas y los elementos de la Gestión del Riesgo Operacional con el fin de determinar las deficiencias y sus posibles soluciones.
- Implementar y realizar seguimiento permanente a las políticas y planes de acción

relacionados con la Gestión de Riesgos Operacional.

- Establecer y monitorear el perfil de riesgo operacional consolidado de la Organización, e informarlo a la Presidencia.

Sistema Integrado de Gestión

El Sistema Integrado de Gestión a través de la Jefatura es responsable de:

- Definir los instrumentos, metodologías y procedimientos tendientes a que se administre efectivamente los riesgos operacionales, de acuerdo con las disposiciones establecidas en el presente documento.
- Establecer y monitorear el perfil de riesgo individual por proceso y consolidado de la Organización, e informarlo a la Vicepresidencia Servicios de Tecnología (Representante de la Alta Dirección SIG).
- Implementar y realizar seguimiento permanente de los procedimientos y planes de acción relacionados con la Gestión de Riesgos Operacional y, proponer sus correspondientes actualizaciones y modificaciones.
- Desarrollar capacitaciones tendientes a fortalecer la Gestión del Riesgo Operacional.
- Evaluar periódicamente la efectividad y cumplimiento de todas y cada una de las etapas y los elementos de la Gestión del Riesgo Operacional con el fin de determinar las deficiencias y sus posibles soluciones.
- Hacer seguimiento a las acciones correctivas o de mejora, que conlleven al fortalecimiento de la Gestión de Riesgo Operacional.

Dueños de Procesos / Dueños de los Riesgos

Las responsabilidades de los Dueños de Proceso relacionadas con la gestión de los riesgos son las siguientes:

- Coordinar la identificación de riesgos de proceso y estratégicos o de negocio con las áreas correspondientes.

- Analizar los riesgos asociados a su proceso y todas sus características para validar su pertinencia.
- Generar acciones correctivas o de mejora, que conlleven al fortalecimiento de la Gestión de Riesgos Operacionales. Estas acciones deben ser reportadas al Sistema Integrado de Gestión con el objetivo de centralizar la información; pueden provenir de planes operativos, planes de acción o proyectos en curso dentro de la Organización.
- Realizar seguimiento a las medidas adoptadas para mitigar el riesgo, con el propósito de evaluar su efectividad.
- Reportar los eventos de riesgo generados en sus procesos.

Auditores de Calidad

- Análisis y evaluación de la eficacia de las acciones tomadas para abordar los riesgos y oportunidades.

Todos los Trabajadores

Todos los Trabajadores y personal externo que realizan funciones para Compunet son responsables de la administración del riesgo, y deben reportar a los Dueños de los Procesos en los que participan o a su superior inmediato, todos los eventos de riesgo que surjan en el desarrollo de sus actividades; además proponer alternativas de mejora tendientes a reducir los niveles de exposición de riesgo de la Organización.

8. CONTROLES OPERATIVOS

Con el fin de contribuir a la adecuada administración de riesgos operacionales, se han definido los siguientes controles operativos:

Descripción del Control	Responsable	Tipo de Control	Ejecución del Control	Origen del Control	Frecuencia	Documentos y Registros
Análisis detallado de los riesgos operacionales por parte de los Dueños mínimo una vez al año (en caso de no presentar cambios incluir su justificación).	Dueño del Proceso	Correctivo	Manual	Mandatorio	Anual o BIANUAL	Correo electrónico de revisión Actualización del registro F.RI.001 Registro Matriz de Riesgos Operacionales por parte de los dueños de proceso.
Ejecutar los controles operativos a cargo definidos y asignados en cada procedimiento.	Ejecutores de los Controles	Preventivo	Manual	Mandatorio	Por Evento o Diario	Evidencias de ejecución de los controles.
Revisión de nuevos riesgos reportados y/o seguimiento de acuerdo con los riesgos previamente identificados y vigentes en la matriz de riesgos	Dueños de Proceso	Detectivo	Manual	Mandatorio	Por Evento o Diario	Correo electrónico confirmando revisión Actualización del registro F.RI.001 Registro Matriz de Riesgos Operacionales por parte de los dueños de proceso.
Verificación de la eficacia de los controles asociados a cada riesgo	Jefe Sistema Integrado de Gestión	Correctivo	Manual	Mandatorio	Semestral	Actualización del registro F.RI.001 Registro Matriz de Riesgos Operacionales campo

Descripción del Control	Responsable	Tipo de Control	Ejecución del Control	Origen del Control	Frecuencia	Documentos y Registros
	Especialista de Seguridad de la Información					"Evaluación de los controles"
Capacitaciones y divulgaciones sobre riesgos operacionales recordando la responsabilidad de identificación y/o actualización de los mismos.	Jefe Sistema Integrado de Gestión y/o Especialista de Seguridad de la Información	Preventivo	Manual	Mandatorio	Anual o Bianual	Evidencias de las capacitaciones y/o divulgaciones.
Revisión y/o actualización de los controles operativos asociados a cada riesgo para validar su pertinencia y aplicación	Dueños de Proceso	Preventivo	Manual	Mandatorio	Anual o Bianual	Correo electrónico confirmando revisión Actualización del registro F.RI.001 Registro Matriz de Riesgos Operacionales por parte de los dueños de proceso.

9. RESPONSABILIDAD

Es responsabilidad del Jefe del Sistema Integrado de Gestión promulgar, hacer cumplir y difundir este documento.

10. DOCUMENTOS DE REFERENCIA

10.1 Internos

Código	Nombre
M.RI.002	Metodología de Gestión de Riesgos de la Seguridad de la Información
P.RI.013	Identificación de Peligros Evaluación y Valoración de Riesgos

P.GI.004	Correcciones, Acciones Correctivas y Acciones de Mejora
F.CO.002	Plan de Comunicaciones del SIG
F.RI.001	Matriz de Riesgos Operacionales
F.RI.052	Matriz y Mapa de Riesgos de la Seguridad de la Información
F.RI.050	Matriz de Identificación de los Peligros, Evaluación y Valoración de Riesgos

10.2 Externos

Entidad	Nombre del documento
NA	NA

11. CAMBIOS EN EL DOCUMENTO

Fecha de Publicación	Versión	Tipo de Cambio	Detalle del Cambio
28/08/2024	14	Modificación	- Ajuste general de cargos. - Se trasladan las definiciones al documento Banco de Definiciones y se registra el link de consulta.